

Vulnerability Assessment Report

29th September 2026

System Description

The system under assessment is a remote database server used by an e-commerce company to store critical customer information. Global employees query this database daily to support business operations. The primary vulnerability is that the database has been exposed to the public internet without proper access controls or authentication mechanisms since its launch three years ago.

Scope

In alignment with NIST SP 800-30 Rev. 1 guidelines, this risk assessment is conducted at the Tier 3 (Information System) level. The scope is strictly limited to evaluating the logical access controls, security configurations, and the risks associated with the public exposure of the database server. It focuses on identifying threat sources and events that could compromise data confidentiality, integrity, and availability. Physical security and the broader corporate IT infrastructure fall outside the defined system boundary and are out of scope.

Purpose

Conducting a vulnerability assessment on the remote database server is critical for safeguarding sensitive customer information and maintaining business operations. The database is highly valuable because it stores essential client data that remote employees query daily to drive business growth. Securing this data is vital to preserving customer trust and protecting the company's reputation. If the server is compromised or disabled, the company faces severe consequences, including significant financial loss, legal liabilities, and irreversible damage to client confidence.

Risk Assessment

Threat source	Threat event	Likelihood	Severity	Risk
<i>Hacker</i>	<i>Obtain sensitive information via exfiltration</i>	3	3	9
<i>Employee</i>	Disrupt mission-critical operations.	2	3	6
<i>Customer</i>	Alter/Delete critical information	1	3	3

Approach

I selected these three threat sources—Hackers, Employees, and Customers—because they represent the most realistic and immediate risks to a publicly exposed database. Since the server has been open to the public for three years, the likelihood of a hacker discovering and exfiltrating sensitive data is exceptionally high. Furthermore, intentional network disruptions by malicious employees or accidental data alterations by customers could severely impact daily operations. Highlighting these qualitative threats helps stakeholders understand the critical vulnerabilities impacting data confidentiality, integrity, and availability.

Remediation Strategy

To remediate these risks, the company must immediately remove the database from public access and secure it behind a configured firewall or Virtual Private Network (VPN). Implementing a strict Authentication, Authorization, and Accounting (AAA) framework combined with Multi-Factor Authentication (MFA) will ensure that only verified personnel can access the system. Additionally, applying the principle of least privilege will limit user permissions strictly to what is required for their specific roles. This defense-in-depth strategy significantly minimizes the attack surface against both external and internal threats.